Unit 4 - Web Security (updated to textbook contents)

Cryptography and Web Security (DI03016021) - GTU Diploma IT Sem 3

24% weightage | 10 hours | follows your textbook order

How to use these notes: topics follow your textbook order (4.1 to 4.5) plus the exam question-answer section. **3 marks** = definition + 2-3 points. **4 marks** = add example or table. **7 marks** = everything with diagram and table. Lines marked ★ were already asked in a GTU paper (Winter 2025 / Summer 2026).

GTU questions already asked from this unit (do these first)

- BOTH papers: W2025 Q4(a) [3M] + S2026 Q4(a) [3M]
- BOTH papers: W2025 Q4(a)OR [3M] + S2026 Q5(a) [3M]
- BOTH papers: W2025 Q4(b) [4M] + S2026 Q4(b) [4M]
- S2026 Q4(a)OR [3M: functions of TLS record and TLS alert protocols]
- S2026 Q4(b)OR [4M: differentiate SSL vs TLS]
- HTTPS in BOTH papers: W2025 Q4(b)OR [4M] + S2026 Q4(c) [7M]
- SET in BOTH papers (7M each): W2025 Q4(c) + S2026 Q4(c)OR
- BOTH papers: W2025 Q4(c)OR [7M] + S2026 Q5(a)OR [3M]

4.1.1 What is web security: definition and objectives

Textbook 4.1.1: what is web security, definition, objectives

Definition: Web security is the practice of protecting **websites, web applications, servers, databases and users** from cyber-attacks, and making sure that information stays **confidential, accurate and available only to authorised users**.

- Websites handle sensitive data such as **passwords, credit-card details and personal data**, so strong security is essential.
- Without security, attackers can **steal data, change website content, spread malware or stop online services**.

Objectives of web security

- Protect confidential information from unauthorised access.
- Ensure only authorised users can access resources.
- Prevent unauthorised modification of data.
- Maintain availability of websites and services.
- Protect user privacy and prevent identity theft.
- Prevent financial fraud and other cyber-attacks.
- Build user trust and protect the organisation's reputation.

4.1.1 Web security threats by category (syllabus)

★ BOTH papers: W2025 Q4(a) [3M] + S2026 Q4(a) [3M]

Threats are grouped by what they damage:

Threat type	Examples of threats	Consequence	Countermeasure
Integrity	Modification of user data; Trojan-horse browser; modification of memory; modification of messages in transit	Loss of data, machine compromise	Cryptographic checksums (hash, MAC)
Confidentiality	Eavesdropping on the network; theft of info from server or client; info about network configuration; traffic analysis	Loss of information and privacy	Encryption, web proxies
Denial of Service	Killing user threads; flooding with bogus requests; filling disk / memory; DNS attacks	Disruption of service	Difficult to prevent fully
Authentication	Impersonation of legitimate users; data forgery	Misrepresentation of user	Cryptographic techniques (certificates)

Exam tip: 3 marks 'three threats': write Integrity, Confidentiality and Denial of Service with one example line each.

4.1.2 Need for web security

Textbook 4.1.2: need for web security

1. **Protect sensitive data** - passwords, card numbers, personal and business records.
2. **Safe e-commerce and net banking** - online payments need trust and secure transactions.
3. **Stop cyber-attacks** like malware, phishing, SQL injection, DDoS that cause loss and downtime.
4. **Prevent financial loss and fraud** (stolen money, fake orders).
5. **Legal and privacy compliance** - laws require protection of user data.
6. **Keep reputation and customer trust** - a hacked site loses customers.
7. **Keep services available** 24x7 for genuine users.

4.1.3 Types of web security threats

Textbook 4.1.3: types of web security threats (all 8)

Eight common web threats - for each learn **meaning, example and prevention**:

Threat	Meaning	Example	Prevention
1. Malware	Malicious software that damages or steals data: virus, worm, trojan, ransomware, spyware	Ransomware locks files and demands money	Antivirus, updates, no unknown downloads
2. Phishing	Fake emails / websites that trick users into giving passwords, card or OTP details	Fake bank website link in an email	Check URL, never share OTP, 2-factor login, awareness
3. Password attacks	Guessing or stealing passwords: brute force, dictionary attack, credential stuffing, keylogger	Trying thousands of passwords on a login page	Strong passwords, account lock, multi-factor authentication, store hashed passwords
4. SQL Injection (SQLi)	Attacker enters malicious SQL code in input fields so the database runs it - can read, change or delete data	Typing `' OR '1'='1` in a login box to bypass login	Parameterised queries, input validation, least-privilege DB account
5. Cross-Site Scripting (XSS)	Attacker injects malicious JavaScript into a page that other users view; it runs in their browser and steals cookies / session. Types: stored, reflected, DOM-based	Script hidden in a comment box steals visitors' cookies	Input validation, output encoding, Content Security Policy
6. DoS / DDoS	**DoS:** flooding a server with requests from one source so genuine users cannot use it. **DDoS:** same attack from **many machines (botnet)** at once	Millions of fake requests crash a shopping site on sale day	Firewall, rate limiting, load balancer, CDN / DDoS protection
7. Man-in-the-Middle (MITM)	Attacker secretly sits between user and server, reads or changes the data in transit	Fake free Wi-Fi hotspot capturing passwords	HTTPS / TLS, VPN, certificate checks, avoid public Wi-Fi
8. Session hijacking	Attacker steals a user's **session ID / cookie** and acts as that logged-in user	Stealing the cookie of a logged-in email account	HTTPS, Secure and HttpOnly cookies, session timeout, new session ID after login

Exam tip: For a 3-mark 'explain any one threat' question write: definition + one example + two prevention points.

4.1.4 Web traffic security approaches (levels)

★ BOTH papers: W2025 Q4(a)OR [3M] + S2026 Q5(a) [3M]

Web traffic security can be added at **three levels** of the protocol stack:

Level	Protocol	How it works	Pros / cons
Network level	IPsec	Security added at the IP layer; encrypts / authenticates all IP packets	Transparent to applications; needs OS / router support
Transport level	SSL / TLS	Sits between TCP and the application; secures any TCP application	Most common for web (HTTPS); built into browsers
Application level	SET, S/MIME, PGP, Kerberos	Security built into the application	Tailored to the application, but each application needs its own

4.1.4 Secure communication, VPN and digital certificates

Textbook 4.1.4: secure communication over the Internet, VPN, digital certificates

1) Secure communication over the Internet

Data travelling on the internet passes through many unknown devices, so it can be read or changed. **Secure communication** uses **encryption, authentication and integrity checks** so that data stays private and unchanged between sender and receiver. Protocols used: **SSL / TLS, HTTPS, IPsec, VPN**; digital certificates prove identity.

2) VPN (Virtual Private Network) - brief

- A VPN creates an **encrypted tunnel** over the public internet between a user (or office) and a private network, so the data looks like it travels on a private line.
- **Types:** remote-access VPN (employee to office) and site-to-site VPN (office to office). **Protocols:** IPsec, SSL/TLS VPN, OpenVPN.
- **Benefits:** confidentiality on public Wi-Fi, hides IP address, secure access to company resources.

3) Digital certificates

- A **digital certificate** is an electronic document that **binds a public key to the identity** of a person / website. It is issued and digitally signed by a trusted **Certificate Authority (CA)**. Standard format: **X.509**.
- **Contents:** owner's name, owner's public key, issuer (CA) name, serial number, validity period, digital signature of CA.
- **Use:** when you open an https:// site, the server sends its certificate; the browser verifies the CA's signature, the validity date and the domain name before trusting the site (padlock icon).

4.1.4 Comparison of different web traffic security approaches

Textbook 4.1.4: comparison of different web traffic security approaches

Approach	Layer	What it does	Protects	Example use
IPsec	Network	Encrypts / authenticates all IP packets	All traffic between two networks / hosts	Site-to-site VPN
SSL / TLS	Transport (above TCP)	Encrypts and authenticates a TCP connection	Any application using TCP (HTTP, FTP, mail)	Secure browsing, email
HTTPS	Application (HTTP over TLS)	HTTP traffic carried inside TLS	Web pages, forms, cookies	Online shopping, banking
VPN	Network / Transport	Encrypted tunnel over the internet	All traffic of the user / office	Work from home, public Wi-Fi
Digital certificate	Supports all	Proves identity of server / user (via CA)	Authenticity (not the data by itself)	Server identity in HTTPS
SET / S-MIME / PGP	Application	Application-specific security	Card payment / email	Credit-card payment, secure email

4.2.1 Overview of SSL protocol stack

★ BOTH papers: W2025 Q4(b) [4M] + S2026 Q4(b) [4M]

Handshake Protocol	Change Cipher Spec	Alert Protocol	HTTP
SSL Record Protocol			
TCP			
IP			

SSL (Secure Socket Layer) was developed by Netscape. It provides **confidentiality** and **message integrity** for TCP-based applications. It is a **two-layer** protocol:

- **SSL Record Protocol** (lower layer): fragment → compress → add MAC → encrypt → add header.
- **Handshake Protocol:** client and server authenticate each other and negotiate encryption algorithm, MAC algorithm and keys.
- **Change Cipher Spec Protocol:** a single message (value 1) telling the other side to start using the newly agreed keys.
- **Alert Protocol:** alert messages with level (**warning** or **fatal**) and a code; fatal ends the connection.

4.2.2 SSL architecture

Textbook 4.2.2: SSL architecture (connection, session, handshake)

SSL architecture has **two layers**: the **SSL Record Protocol** (below) and three upper-layer protocols - **Handshake, Change Cipher Spec, Alert** - which run on top of TCP.

Handshake	Change Cipher Spec	Alert	HTTP
SSL Record Protocol			
TCP			
IP			

Two important concepts

- **SSL connection:** a temporary peer-to-peer transport link between client and server. Each connection belongs to one session. Connection state: server and client random numbers, MAC secrets, encryption keys, sequence numbers.
- **SSL session:** an association between client and server created by the Handshake Protocol. It defines cryptographic parameters (session ID, peer certificate, compression method, cipher spec, master secret) that many connections can share, so the expensive handshake need not be repeated.

Handshake protocol - 4 phases

Phase	Messages	Purpose
1. Establish security capabilities	client_hello, server_hello	Agree on protocol version, cipher suite, compression, random values
2. Server authentication and key exchange	certificate, server_key_exchange, certificate_request, server_hello_done	Server proves identity and sends key material
3. Client authentication and key exchange	certificate, client_key_exchange, certificate_verify	Client authenticates (optional) and sends the pre-master secret
4. Finish	change_cipher_spec, finished	Switch to the new cipher keys and verify the handshake

4.2.3-4.2.4 SSL Record protocol and Change Cipher Spec protocol

Textbook 4.2.3-4.2.4: SSL Record protocol and Change Cipher Spec

SSL Record Protocol (4.2.3)

Gives **confidentiality** (encryption with a shared secret key) and **message integrity** (MAC) to data of the upper layers. Steps (sender side):



The receiver does the reverse: decrypt → verify MAC → decompress → reassemble. The record header contains content type, version and length.

Change Cipher Spec Protocol (4.2.4)

- The simplest SSL protocol: it consists of **one message of a single byte with value 1**.
- Its job: to **copy the pending cipher state into the current state**, i.e. tell the other side 'from now on use the newly agreed algorithms and keys'.
- It is sent by both client and server at the end of the handshake, just before the **finished** message.

Alert protocol (TLS record and alert functions)

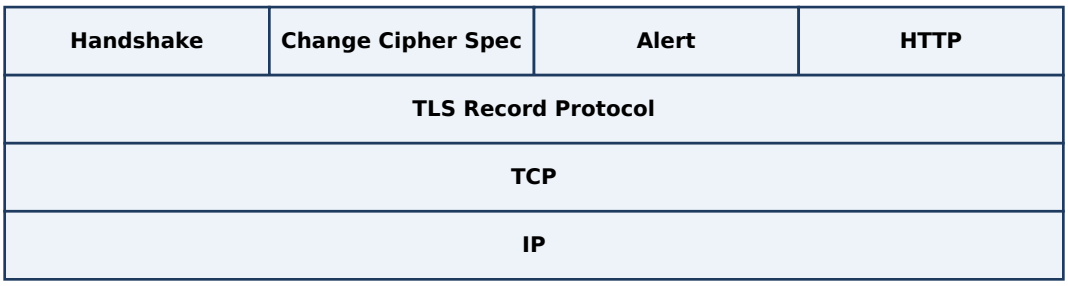
★ S2026 Q4(a)OR [3M: functions of TLS record and TLS alert protocols]

- **TLS Record protocol** - gives **confidentiality** (symmetric encryption) and **message integrity** (HMAC). It fragments data, optionally compresses, adds the MAC, encrypts and adds a header.
- **TLS Alert protocol** - carries alert messages; each has **level** (warning = 1, fatal = 2) and **code**. A fatal alert (e.g. bad_record_mac, handshake_failure) terminates the connection at once; close_notify closes it politely.

4.2.5 and 4.2.7 TLS protocol stack and TLS architecture

Textbook 4.2.5 + 4.2.7: overview of TLS protocol stack and TLS architecture

TLS (Transport Layer Security) is the standardised (IETF, RFC 2246) successor of SSL 3.0. Its architecture is the same as SSL: a **Record layer** carrying the Handshake, Change Cipher Spec and Alert protocols for applications such as HTTP.



- **TLS Record Protocol:** fragmentation → (compression) → **HMAC** → encryption → header. Gives confidentiality and integrity.
- **Handshake Protocol:** negotiates version, cipher suite, authenticates the server (and optionally the client) with certificates and creates shared keys using a pseudo-random function (PRF).
- **Change Cipher Spec:** activates the negotiated cipher keys.
- **Alert Protocol:** reports problems with level warning / fatal (e.g. close_notify, bad_record_mac, handshake_failure).
- Modern versions: TLS 1.2 and **TLS 1.3** (faster handshake, only strong algorithms). SSL itself is now considered insecure.

4.2.6 SSL vs TLS

★ S2026 Q4(b)OR [4M: differentiate SSL vs TLS]

Point	SSL	TLS
Full form / developer	Secure Socket Layer - Netscape	Transport Layer Security - IETF (RFC 2246)
Version	SSL 3.0	TLS 1.0 = SSL 3.1 (later TLS 1.2, 1.3)
Message authentication	Own MAC algorithm	**HMAC** (standard, stronger)
Key generation	Ad-hoc method	Pseudo-random function (PRF) based on HMAC
Alert messages	Fewer alert codes	More alert codes
Cipher suites	Supports Fortezza	Fortezza removed
Status	Deprecated / insecure	In use (TLS 1.2 / 1.3)

4.3 HTTPS: connection initiation and closure

★ HTTPS in BOTH papers: W2025 Q4(b)OR [4M] + S2026 Q4(c) [7M]

Full forms: TLS = Transport Layer Security; **HTTPS** = HyperText Transfer Protocol Secure (HTTP over SSL/TLS), port **443**, URL starts with **https://**.

Connection initiation

The HTTP client also acts as the **TLS client**:



1. Client opens a TCP connection to the server on port 443.
2. TLS handshake: **ClientHello** (supported ciphers); server replies **ServerHello** and its **certificate**.
3. Client verifies the certificate, both sides exchange keys, agree on session keys and send **Finished**.
4. Only then the client sends the **HTTP request**; URL, headers, cookies, form data and page content are all **encrypted**.

Connection closure

1. Either side can close the connection; HTTP may say **Connection: close**.
2. Before closing TCP, TLS sends a **close_notify** alert so the other side knows the closure is genuine.
3. Then the **TCP connection is closed**.
4. TCP closed **without** close_notify = possible **truncation attack**; client reports an error. The session can be resumed later using the session ID.

4.4 Secure Electronic Transactions (SET): participants and sequence

★ SET in BOTH papers (7M each): W2025 Q4(c) + S2026 Q4(c)OR

SET (Secure Electronic Transaction) is an open protocol by **Visa and MasterCard (1996)** to protect **credit-card payments over the internet**, using X.509 digital certificates and a **dual signature**.

Services

- Confidentiality of payment and order information.
- Integrity of all data.
- Authentication of cardholder and merchant.
- Privacy: merchant sees only the order, bank only the payment.

Participants and their role

Participant	Role
Cardholder	Authorised holder of a payment card; places the order and pays.
Merchant	Seller of goods / services; accepts card payments (has certificates).
Issuer	Bank that issued the card; guarantees payment if the transaction is valid.
Acquirer	Merchant's bank; processes card authorisations and payments.
Payment gateway	Operated by the acquirer; links SET to the banking network.
Certification Authority (CA)	Issues X.509v3 certificates to cardholders, merchants and gateways.

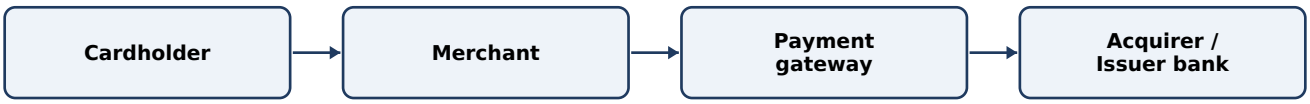
Sequence of events in a transaction

1. Customer **opens an account** with a card-issuing bank.
2. Customer **receives a certificate** signed by the bank.
3. **Merchants have their own certificates** (signing and key exchange).
4. Customer **places an order**.
5. Merchant sends its certificate so the customer can **verify the merchant**.
6. Customer sends **order and payment information** with a **dual signature**.
7. Merchant **requests payment authorisation** from the payment gateway.
8. Merchant **confirms the order**.
9. Merchant **ships the goods**.
10. Merchant **requests payment** from the gateway.

4.4.1-4.4.2 Online card payment using SET and SET components

Textbook 4.4.1-4.4.2: online card payment using SET, SET components

Online card payment using SET (flow)



1. Cardholder and merchant first get **digital certificates** from the Certificate Authority (CA).
2. Cardholder selects goods; the merchant sends an **invoice and its certificate**.
3. Cardholder sends **Order Information (OI)** for the merchant and **Payment Information (PI)** for the bank, linked with a **dual signature**; PI is encrypted so the merchant cannot read the card number.
4. Merchant verifies the cardholder and forwards the PI to the **payment gateway** asking for authorisation.
5. Gateway contacts the acquirer and **issuer bank**, which approves or rejects the payment.
6. Merchant **confirms the order** and ships the goods; later requests **capture (settlement)** of the money.

Dual signature

Purpose: link OI and PI so they cannot be separated, while merchant sees only OI and bank sees only PI. The customer computes hashes of PI and OI, joins them, hashes again and **signs with the private key**: **DS = $E(PR_{customer}, H(H(PI) || H(OI)))$**.

SET components

- **Participants:** cardholder, merchant, issuer, acquirer, payment gateway, certification authority (CA).
- **Technologies:** digital certificates (X.509), **dual signature**, digital envelope (symmetric key encrypted with public key), digital wallet software on the customer side.

4.4.3 Need for SET

Textbook 4.4.3: need for SET

1. **Protects card details** - the merchant never sees the card number; the bank never sees the order details.
2. **Authenticates all parties** (cardholder, merchant, bank) with certificates, so fake shops and stolen cards are harder to use.
3. **Ensures integrity** - order and payment cannot be changed in transit.
4. **Prevents fraud and repudiation** - digital signatures prove who ordered and paid.
5. **Builds trust** in online credit-card shopping and gives a common open standard for banks and merchants.

4.5.1 SSL vs SET comparison

★ BOTH papers: W2025 Q4(c)OR [7M] + S2026 Q5(a)OR [3M]

Point	SSL	SET
Purpose	General-purpose security for any TCP application	Specially for **credit-card payments** on the web
Layer	Transport layer (between TCP and application)	Application layer
Authentication	Server authenticated; client optional	**All parties** authenticated with certificates
Card details	Merchant can see the card number	Merchant **never sees** the card number (dual signature)
Non-repudiation	Not provided	Provided (digital signatures)
Complexity / cost	Simple, built into browsers	Complex, needs special software and certificates for all
Use today	Very widely used (HTTPS)	Rarely used now

Exam tip: 3 marks: write only the first three rows. 7 marks: all rows.

4.5.2 SSL and SET architecture comparison

Textbook 4.5.2: SSL and SET architecture comparison

Point	SSL architecture	SET architecture
Position in stack	Between TCP (transport) and application layer	Application-layer protocol (runs above HTTP / TCP)
Parties involved	Two parties: **client and server**	Multiple parties: cardholder, merchant, issuer, acquirer, gateway, CA
Components	Record, Handshake, Change Cipher Spec, Alert protocols	Certificates, dual signature, digital envelope, payment gateway
Trust model	Server certificate (client certificate optional)	Certificates for **all** participants from a CA hierarchy
Applications	Any TCP application (web, mail, FTP)	Only credit-card payment transactions

4.5.3 SSL and SET security features comparison

Textbook 4.5.3: SSL and SET security features comparison

Security feature	SSL	SET
Confidentiality	Yes - whole session data encrypted	Yes - order and payment info separately encrypted
Integrity	Yes - MAC on every record	Yes - digital signatures and hashes
Authentication	Server always; client optional	Cardholder, merchant and gateway all authenticated
Non-repudiation	No	Yes (dual signature)
Hides card number from merchant	No	Yes
Key / certificate use	Server certificate, session keys	Certificates for every party, digital envelope
Ease of use / adoption	Easy, built in browsers, widely used	Complex, special software, rarely used now

EXAM QUESTION ANSWER SECTION - Short answers (3 marks)

Textbook exam section: Short answers (3 marks)

1. **Define web security.**

   Web security is the practice of protecting websites, web applications, servers, databases and users from cyber-attacks and ensuring information stays confidential, accurate and available only to authorised users.

2. **List any four objectives of web security.**

   Protect confidential data; allow only authorised access; prevent unauthorised modification; keep services available; protect user privacy; prevent financial fraud.

3. **What is phishing?**

   Phishing is an attack in which fake emails or websites trick users into giving passwords, card numbers or OTPs. Prevention: check the URL, never share OTP, use two-factor login.

4. **What is SQL injection?**

   Attacker enters malicious SQL code in an input field so the database executes it and exposes or changes data. Prevention: parameterised queries and input validation.

5. **What is Cross-Site Scripting (XSS)?**

   Injecting malicious JavaScript into a web page that runs in other users' browsers and can steal cookies or sessions. Prevention: input validation, output encoding, Content Security Policy.

6. Differentiate DoS and DDoS.

DoS floods a server from a single source; DDoS does the same from many compromised machines (botnet) at once, so it is harder to stop.

7. What is a Man-in-the-Middle attack?

The attacker secretly sits between two communicating parties and reads or alters data. Prevented by HTTPS/TLS and VPN.

8. What is session hijacking?

Stealing a user's session ID or cookie to act as that logged-in user. Prevention: HTTPS, secure / HttpOnly cookies, session timeout.

9. What is a VPN?

A Virtual Private Network creates an encrypted tunnel over the public internet to give secure access to a private network.

10. What is a digital certificate?

An electronic document, signed by a Certificate Authority, that binds a public key to the identity of a person or website (X.509 format).

11. Name the protocols of the SSL stack.

Handshake Protocol, Change Cipher Spec Protocol, Alert Protocol (on top of) the SSL Record Protocol.

12. Full forms of TLS and HTTPS.

TLS = Transport Layer Security; HTTPS = HyperText Transfer Protocol Secure.

13. What is the need of SET?

To protect credit-card details, authenticate cardholder, merchant and bank, and keep order and payment information private using dual signature.

14. What is dual signature?

A signature that links Order Information and Payment Information so the merchant sees only the order and the bank only the payment, but they cannot be separated.

EXAM QUESTION ANSWER SECTION - Medium and Long questions (4 and 7 marks)

Textbook exam section: Medium (4 marks) and Long (7 marks) question list with where to find the answer

Medium questions (4 marks)

Question	Answer is in section
Explain types of web security threats (any four)	4.1.3 Types of web security threats
Discuss web threats on integrity and confidentiality	4.1.1 Threats by category
Draw and explain SSL protocol stack	4.2.1 / 4.2.2
Explain SSL Record protocol	4.2.3
Differentiate SSL and TLS	4.2.6
Explain HTTPS connection initiation	4.3.1
Explain need of SET	4.4.3
Compare VPN and digital certificate / explain digital certificate	4.1.4

Long questions (7 marks)

Question	Answer is in section
Explain web security threats and their prevention	4.1.3 Types of web security threats
Explain web traffic security approaches with comparison	4.1.4 + comparison table
Explain SSL architecture: connection, session, handshake phases	4.2.2
Explain SSL protocols: Handshake, Record, Change Cipher Spec, Alert	4.2.2 - 4.2.4
Explain HTTPS connection initiation and closure	4.3
Explain SET: participants, online payment flow and sequence of events	4.4
Compare SSL with SET (features, architecture)	4.5

EXAM QUESTION ANSWER SECTION - Multiple Choice Questions (MCQs)

Textbook exam section: Multiple Choice Questions (practice)

1. SSL stands for
(a) Secure Sockets Layer (b) Safe Socket Link (c) System Security Layer (d) Secure Server Login
Answer: (a) Secure Sockets Layer

2. The default port number of HTTPS is
(a) 80 (b) 21 (c) 443 (d) 25
Answer: (c) 443

3. The SSL protocol that negotiates algorithms and keys is the
(a) Record protocol (b) Handshake protocol (c) Alert protocol (d) Change Cipher Spec
Answer: (b) Handshake protocol

4. Inserting malicious SQL code through input fields is called
(a) XSS (b) SQL Injection (c) Phishing (d) MITM
Answer: (b) SQL Injection

5. XSS stands for
(a) Cross-Site Scripting (b) Cross-System Security (c) Extra Site Security (d) XML Site Script
Answer: (a) Cross-Site Scripting

6. DDoS attacks are usually launched using a
(a) Botnet (b) Firewall (c) VPN (d) Certificate
Answer: (a) Botnet

7. SSL works between
(a) IP and Ethernet (b) TCP and the application layer (c) Application and user (d) Physical and data link
Answer: (b) TCP and the application layer

8. SET was developed by
(a) Google and Microsoft (b) Visa and MasterCard (c) Intel and IBM (d) Netscape
Answer: (b) Visa and MasterCard

9. A digital certificate is issued by a
(a) Web server (b) Certificate Authority (CA) (c) Browser (d) ISP
Answer: (b) Certificate Authority (CA)

10. The standard format of digital certificates is
(a) X.509 (b) RSA (c) AES (d) DES
Answer: (a) X.509

11. The two levels of an SSL / TLS alert are
(a) Low and high (b) Warning and fatal (c) Minor and major (d) Info and error
Answer: (b) Warning and fatal

12. The alert used to close a connection properly is
(a) bad_record_mac (b) close_notify (c) handshake_failure (d) unexpected_message
Answer: (b) close_notify

13. TLS 1.0 is equivalent to
(a) SSL 1.0 (b) SSL 2.0 (c) SSL 3.1 (d) SSL 4.0
Answer: (c) SSL 3.1

14. A VPN creates a(n)
(a) Encrypted tunnel (b) Firewall rule (c) Virus (d) Hash
Answer: (a) Encrypted tunnel

15. Dual signature is used in
(a) SSL (b) SET (c) IPsec (d) HTTP
Answer: (b) SET

16. Phishing means
(a) Flooding a server (b) Tricking users with fake emails / sites (c) Stealing a session ID (d) Encrypting data
Answer: (b) Tricking users with fake emails / sites

17. Session hijacking steals the
(a) Firewall (b) Session ID / cookie (c) Hash (d) Public key
Answer: (b) Session ID / cookie

18. SSL Record protocol provides
(a) Only compression (b) Confidentiality and message integrity (c) Only authentication (d) Routing
Answer: (b) Confidentiality and message integrity

19. The Change Cipher Spec protocol consists of a message of
(a) 1 byte with value 1 (b) 4 bytes (c) a certificate (d) a hash
Answer: (a) 1 byte with value 1

20. Man-in-the-Middle attack means
(a) Attacker intercepts communication between two parties (b) Server crash (c) Password guessing (d) Virus spreading
Answer: (a) Attacker intercepts communication between two parties

Last-minute revision sheet - Unit 4

- 8 threats: malware, phishing, password attacks, SQL injection, XSS, DoS/DDoS, MITM, session hijacking - know meaning + example + prevention.
- Approaches: IPsec (network), SSL/TLS (transport), HTTPS, VPN (encrypted tunnel), digital certificate (X.509, issued by CA), SET / S-MIME / PGP (application).
- SSL stack: Handshake, Change Cipher Spec, Alert over Record protocol, over TCP. Handshake has 4 phases.
- Record protocol: fragment → compress → MAC → encrypt → header. Change Cipher Spec = 1 byte, value 1.
- Alert levels: warning, fatal. close_notify closes the connection.
- TLS = IETF standard of SSL 3.0 (TLS 1.0 = SSL 3.1); uses HMAC and PRF; TLS 1.3 is current.
- HTTPS = HTTP over TLS, port 443; close with close_notify then TCP close.
- SET: Visa + MasterCard; participants cardholder, merchant, issuer, acquirer, gateway, CA; dual signature = E(PR, H(H(PI)||H(OI))).
- SSL vs SET: general vs credit-card only; transport vs application layer; server-only auth vs all parties; merchant sees card vs hidden.